Operational Security – 1AIER – 09 de Novembro de 2026
Ficha do Sistema: SupportBot *(briefing para a modelagem do Lab 1)*

O que é

O **SupportBot** é um agente de atendimento que opera a caixa de suporte de uma empresa. Recebe e-mails de clientes e resolve pedidos simples **sozinho** — consulta dados, responde e emite reembolsos — sem humano no meio.

Quem interage

- **Cliente** — manda e-mails legítimos (dúvidas, pedidos de reembolso).
- **Atacante** — também pode mandar e-mail: a caixa é pública, qualquer um escreve.
- **Operador de suporte (humano)** — supervisiona, mas hoje **não** aprova as ações do agente.

Componentes e dados

- **Agente SupportBot** — o LLM mais o loop de ferramentas.
- **Base de clientes (PII)** — nomes, e-mails, saldos e histórico de **todos** os clientes.
- **Servidor de e-mail** — de onde lê e por onde responde.
- **API de Pagamentos** — executa os reembolsos.
- **Provedor de LLM** — o modelo que decide a próxima ação.

O que o agente pode fazer (ferramentas)

Ferramenta	Efeito
consultar_saldo	lê o saldo de um cliente (PII)
listar_contas	lê dados de **todos** os clientes (PII em massa)
responder_email	envia e-mail para um destinatário
emitir_reembolso	credita um valor via API de Pagamentos

Credencial: o agente roda com **uma única credencial ampla** que libera as quatro ações — não há escopo por tarefa.

Como funciona — fluxo de dados

1. Um e-mail chega na caixa de suporte (de um **cliente** ou de um **atacante** — o sistema não sabe de antemão qual).
2. O agente monta o contexto: **instruções do sistema + corpo do e-mail, na mesma string**.
3. O LLM lê tudo e **decide** qual ferramenta chamar, com quais argumentos.
4. O agente **executa** a ferramenta: consulta a base de PII, responde um e-mail e/ou emite um reembolso.
5. O resultado volta ao remetente por e-mail.

Sua tarefa

Com **apenas** esta descrição, no Threat Dragon: desenhe o diagrama e as **fronteiras de confiança**; rode a **lethal trifecta**; gere a tabela **STRIDE** (ao menos 4 ameaças); proponha mitigações. O método é o mesmo que você viu no exercício guiado do **CodeReviewer**.